proposed compliance period underestimates the time it would take to implement any final rule.[406] In particular, commenters expressed that advisers will need to holistically reassess their current service provider infrastructure and may need time to find new service providers or renegotiate terms of service provider agreements in order to comply with the rule's requirements.[407] Separately, two commenters urged the Commission to consider a tiered compliance period that staggers the compliance date based on firm size, with larger firms having to comply with the rule's requirements prior to smaller firms.[408] These commenters asserted that a longer compliance period for smaller broker-dealers and investment advisers would allow these firms to benefit from the implementation of larger industry participants.

We have taken commenter concerns into account in determining the compliance schedule,[409] and we are adopting a compliance period of 18-months following the date of publication of the final amendments in the Federal Register for larger entities, and 24-months following the date of publication in the Federal Register for smaller entities.[410] The compliance

---

406 *See*, *e.g.*, IAA Comment Letter 1; FII Comment Letter; SIFMA Comment Letter 2; ICI Comment Letter 1; *see also* IAA Comment Letter 2 (stating that "advisers would need to holistically reassess their current service provider infrastructure and undergo the time-consuming and expensive process of negotiating terms with each Service Provider, re-evaluate their current policies, procedures, and practices in light of any new requirements, prepare for new and/or different client notification obligations, and create and implement modified written incident response program policies and procedures and recordkeeping requirements").

407 *See*, *e.g.*, Google Comment Letter; Federated Comment Letter; SIFMA Comment Letter 2; AWS Comment Letter; FII Comment Letter.

408 IAA Comment Letter 1; FSI Comment Letter.

409 ICI Comment Letter 1; Schulte Comment Letter; IAA Comment Letter 2 (asserting that the Commission's new rules could potentially require investment advisers to establish and implement new regulatory requirements during compressed and overlapping compliance periods while attempting to comply with existing ongoing regulatory obligations). For further discussion of other recent Commission rules that may have overlapping compliance periods for some covered entities, as well as the potential associated costs associated with implementing multiple rules at once, *see infra* section IV.

410 With respect to the compliance period, commenters requested the Commission consider interactions between the proposed rule and other recent Commission rules. In determining compliance dates, the Commission considers the benefits of the rules as well as the costs of delayed compliance dates and potential overlapping compliance dates. For the reasons discussed throughout the release, to the extent that there are costs from overlapping compliance dates, the benefits of the rule justify such costs. *See infra* section IV for a discussion of the interactions of the final amendments with certain other Commission rules.

period we are adopting is designed to strike the appropriate balance between allowing covered institutions adequate time to establish or adjust their data notification compliance practices and allowing customers and investors to benefit from the amended Regulation S-P framework. Taking concerns of smaller entities into account, smaller entities will benefit from having an additional six months to come into compliance with the final amendments, based on feedback from commenters and to the extent that smaller entities may face additional or different challenges in coming into compliance with the final amendments than larger entities. Although we are providing for a longer compliance period than proposed, we are not providing more than 18 or 24 months, as suggested by some commenters, because we have made modifications from the proposal that should alleviate commenters' concerns related to time needed to establish and implement processes to comply with the final amendments. In a modification from the proposal, the final amendments will no longer require covered institutions to have a written contract with its service providers mandating that service providers take appropriate measures to protect against unauthorized access to or use of customer information, but will instead require covered institutions to establish written policies and procedures reasonably designed to oversee, monitor, and conduct due diligence on service providers.[411] Accordingly, the compliance dates will provide an appropriate amount of time for covered institutions to comply with the final amendments.

III. OTHER MATTERS

Pursuant to the Congressional Review Act,[412] the Office of Information and Regulatory Affairs has designated the final amendments as a "major rule" as defined by 5 U.S.C. 804(2). If

---

411 *See supra* section II.A.4.

412 5 U.S.C. 801 *et seq*.

any of the provisions of these rules, or the application thereof to any person or circumstance, is held to be invalid, such invalidity shall not affect other provisions or application of such provisions to other persons or circumstances that can be given effect without the invalid provision or application.

IV. ECONOMIC ANALYSIS

A. Introduction

The Commission is mindful of the economic effects, including the benefits and costs, of the adopted amendments. Section 3(f) of the Exchange Act, section 2(c) of the Investment Company Act, and section 202(c) of the Investment Advisers Act provide that when engaging in rulemaking that requires us to consider or determine whether an action is necessary or appropriate in or consistent with the public interest, to also consider, in addition to the protection of investors, whether the action will promote efficiency, competition, and capital formation. Section 23(a)(2) of the Exchange Act also requires us to consider the effect that the rules will have on competition and prohibits us from adopting any rule that would impose a burden on competition not necessary or appropriate in furtherance of the Exchange Act. The analysis below addresses the likely economic effects of the final amendments, including the anticipated and estimated benefits and costs of the amendments and their likely effects on efficiency, competition, and capital formation. The Commission also discusses the potential economic effects of certain alternatives to the approaches taken in this adoption.

The final amendments require every broker-dealer,[413] every funding portal,[414] every investment company, every registered investment adviser, and every transfer agent to notify affected customers of certain data breaches.[415] To that end, the final amendments require these covered institutions to develop, implement, and maintain written policies and procedures that include an incident response program that is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information,[416] and that includes a customer notification component for cases where sensitive customer information has been, or is reasonably likely to have been, accessed or used without authorization.[417] The final amendments also define the scope of information covered by the safeguards rule and by the disposal rule,[418] and extend the covered population to all transfer agents registered with the Commission or with another appropriate regulatory agency.[419] Finally, the final amendments impose various related

---

413 Notice-registered broker-dealers subject to and complying with the financial privacy rules of the CFTC will be deemed to be in compliance with the final provision through the substituted compliance provisions of Regulation S-P. *See supra* section II.B.3. As discussed above, unless otherwise stated, references elsewhere in this release to "brokers" or "broker-dealers" include funding portals. *See supra* footnote 5. For the purposes of this economic analysis, however, "broker" and "broker-dealer" do not include funding portals because the economic effects of the final amendments on funding portals differ in some respects from the effects on broker-dealers.

414 Pursuant to Regulation Crowdfunding, funding portals "must comply with the requirements of [Regulation S-P] as they apply to brokers." *See* 17 CFR 227.403(b); *see also supra* footnote 5 and accompanying text.

415 Notification is required in the event that sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization. *See* final rule 248.30(a)(4)(i).

416 As discussed above, "customer information" includes not only information of customers of the aforementioned entities, but also information of customers of other financial institutions in the possession of covered institutions. *See supra* section II.B.1 and final rule 248.30(d)(5)(i). In addition, with respect to transfer agents, "customers" refers to "any natural person who is a securityholder of an issuer for which the transfer agent acts or has acted as a transfer agent." *See* final rule 248.30(d)(4)(ii).

417 *See* final rule 248.30(a)(4); *see also supra* section II.A. Notice will not be required, however, if a covered institution has determined, after a reasonable investigation of the facts and circumstances of an incident of unauthorized access to or use of sensitive customer information, that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.

418 Under the final amendments, the safeguards rule applies to "customer information" and the disposal rule applies to "consumer information" and "customer information." *See* final rule 248.30(a)(1), 248.30(b), 248.30(d)(1), and 248.30(d)(5).

419 *See* final rule 248.30(d)(3).

recordkeeping requirements,[420] and include in the regulation an existing statutory exception to annual privacy notice requirements.[421]

The final amendments will affect covered institutions as well as customers who will receive the required notices. The final amendments will also have indirect effects on service providers that receive, maintain, process, or otherwise are permitted access to customer information on behalf of covered institutions: under the final amendments, unauthorized access to or use of sensitive customer information via service providers will fall under the customer notification requirement. The final amendments require that a covered institution's incident response program include the establishment, maintenance, and enforcement of written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of service providers.[422] These policies and procedures must be reasonably designed to ensure that service providers take appropriate measures to protect against unauthorized access to or use of customer information and provide notification to the covered institution of a breach of security resulting in unauthorized access to a customer information system maintained by the service provider.[423]

The main economic effects of the final amendments will result from the notification and incident response program requirements applicable to all covered institutions.[424] For reasons discussed later in this section, the extension of Regulation S-P to transfer agents will have more limited economic effects.[425] Finally, we anticipate the recordkeeping requirements and the

---

420 *See*, *e.g.*, final rule 17 CFR 275.204-2(a). *See also supra* section II.C and footnote 385.

421 *See* final rule 248.5(e).

422 *See* final rule 248.30(a)(5).

423 *See id*.

424 *See infra* sections IV.D.1.a and IV.D.1.b.

425 *See infra* section IV.D.2.b.

incorporation of the existing statutory exception to annual privacy notice requirements to have minimal economic effects, as discussed further below.[426]

The main economic benefits of the final notification and incident response program requirements, as well as the extension of Regulation S-P to include all transfer agents, will result from enhanced protection of customer information. Customers will directly benefit from the opportunity to take appropriate mitigating actions to protect their accounts and information in the event of unauthorized access to or use of their sensitive information. Direct benefits will result from covered institutions allocating additional resources towards policies and procedures, information safeguards, and cybersecurity to comply with the final requirements. There may lastly be indirect benefits from covered institutions undertaking these actions to the extent they seek to avoid reputational harm resulting from the mandated notifications. These additional resources will contribute to reducing the exposure of covered institutions, and of the broader financial system, to incidents resulting in unauthorized access to or use of customer information.[427] The main economic costs from these new requirements will be compliance costs related to the development and implementation of the required policies and procedures, reputational costs borne by firms that would not otherwise have notified customers of a data breach, and indirect costs from increased expenditures on additional safeguards for covered institutions who will choose to make such investments to avoid such reputational costs.[428]

---

426 *See infra* sections IV.D.3 and IV.D.4.

427 While the scope of the safeguards rule and of the final amendments is not limited to cybersecurity, in the contemporary context, their main economic effects are realized through their effects on cybersecurity. *See infra* footnote 507.

428 Throughout this economic analysis, "compliance costs" refers to the direct costs that *must* be borne in order to avoid violating the Commission's rules. This includes costs related to the development of policies and procedures required by the regulation, costs related to delivery of the required notices, and the direct costs of any other required action. As used here, "compliance costs" excludes costs that are not required, but may nonetheless arise as a consequence of the Commission's rules (e.g., reputational costs resulting from disclosure of data breach, or increased cybersecurity spending aimed at avoiding such reputational costs).

We anticipate that the economic benefits and costs of the final notification requirements will—in the aggregate—be limited because all states already require some form of customer notification of certain data breaches,[429] and because many entities are likely to already have response programs in place.[430] Many customers already receive some level of data breach notification under other laws. This means that the benefits and costs, both direct and indirect, will only accrue from actions taken by covered institutions that are not already required by existing rules or caused by existing competitive forces. The final amendments will, however, afford many individuals greater protections by, for example, defining "sensitive customer information" more broadly than the current definitions used by certain states;[431] providing for a 30-day notification outside timeframe that is shorter than the timing currently mandated by many states, including states providing for no deadline or those allowing for various delays;[432] and providing for a more robust notification trigger than in many states.[433] The final amendments also limit the time a service provider can take to notify a covered institution of a breach to 72 hours, which is a shorter period of time than mandated by many states, allowing covered institutions to notify their customers faster if such notification is required under the final amendments.[434] Further, in certain states, state customer notification laws do not apply to entities subject to or in compliance with the GLBA, and the final amendments will help ensure that customers residing

---

429 *See infra* section IV.C.2.a.

430 *See infra* sections IV.C.1 and IV.C.2.

431 *See infra* section IV.D.1.b(3).

432 *See infra* section IV.D.1.b(2).

433 *See infra* section IV.D.1.b(4).

434 Upon receipt of such a notification from a service provider, a covered institution must initiate its incident response program. This may or may not result in the covered institution having to notify customers. *See* final rule 248.30(a)(5)(i); *infra* section IV.D.1.c.

in these states receive notice of a breach if it occurs.[435] The final amendments will help ensure that all customers, regardless of where they reside, receive a minimum of information regarding a given breach affecting their information and are therefore equally able to take appropriate mitigating actions.

For these reasons, the final requirements will improve customers' knowledge of when their sensitive information has been compromised. Specifically, we expect that the adopted Federal minimum standard for notifying customers of certain types of data breaches, along with the preparation of written policies and procedures for incident response, will result in more customers being notified of these data breaches as well as faster notifications for some customers, and that both of these effects will improve customers' ability to act to protect their personal information. Moreover, such improved notification will—in many cases—become public and impose additional reputational costs on covered institutions that fail to safeguard customers' sensitive information. We expect that these potential additional reputational costs will increase the disciplining effect on covered institutions, incentivizing them to improve customer information safeguards and reduce their exposure to data breaches, thereby improving the resilience of the financial system more broadly.[436] This will reduce economic inefficiency in that it will better align customers' and covered institutions' incentives to safeguard customer information, but will also result in new indirect costs for covered institutions who choose to undertake these improvements in order to avoid those potential reputational costs. In addition, by

---

435 *See infra* section IV.D.1.b(1).

436 As discussed below, the final amendments could result in unnecessary notification, which could lead to customer desensitization. *See infra* section IV.D.1. Unnecessary notification could decrease covered institutions' incentives to invest in customer information safeguards in order to avoid reputational costs if unnecessary notification, for example, desensitizes customers to notices. In that scenario, those reputational costs are themselves reduced as a result of unnecessary notification. *See infra* section IV.D.1.b(4) for a discussion of the effects of unnecessary notification.

revealing when breaches occur, the final amendments will help provide customers with information on the effectiveness of covered institutions' customer information safeguards, further helping customers make better-informed decisions when choosing a covered institution.[437]

To the extent that a covered institution does not have policies and procedures to safeguard customer information and respond to unauthorized access to or use of customer information, it will bear the costs to develop and implement the required policies and procedures for the incident response program.[438] Moreover, transfer agents—who were not subject to any of the customer information safeguard provisions of Regulation S-P prior to this adoption—will face additional compliance costs related to the development of policies and procedures that address administrative, technical, and physical safeguards for the protection of customer information.[439]

As adopting policies and procedures involves fixed costs, doing so is very likely to impose a proportionately larger compliance cost on smaller covered institutions as compared to larger covered institutions.[440] This may reduce smaller covered institutions' ability to compete with their larger peers, for whom the fixed costs are spread over more customers.[441] However,

---

437 *See infra* section IV.B.

438 *See infra* section IV.D.1 for a discussion of these costs.

439 That is, they will face the compliance costs of the provisions of Regulation S-P not applicable to registered transfer agents before this adoption. *See* 17 CFR 248.30(a). In addition, transfer agents registered with a regulatory agency other than the Commission will face additional compliance costs to develop, implement, and maintain written policies and procedures that address the proper disposal of customer information, as these transfer agents were not subject to the disposal rule before this adoption. *See* 17 CFR 248.30(b); *see also infra* section IV.D.2.b for a discussion of these costs.

440 If both large and small covered institutions were to undertake the same compliance activities, the fixed costs associated with these activities would impose a proportionately larger compliance cost on smaller covered institutions. *See infra* footnote 722. As discussed below, smaller covered institutions may have to undertake additional activities compared to larger covered institutions, which would result in additional burdens. *See, e.g., infra* section IV.D.1.a.

441 *See infra* sections IV.D.1 and IV.E.

given the considerable competitive challenges arising from economies of scale and scope already faced by smaller firms, we do not anticipate that the costs associated with this adoption will significantly alter these challenges. Similarly, although the final amendments may lead to improvements to capital formation, existing state rules are similar in many respects to the amendments, and so we do not expect the amendments to have a significant impact on capital formation vis-à-vis the baseline.[442]

Many of the benefits and costs discussed below are difficult to quantify. Doing so would involve estimating the losses likely to be incurred by a customer in the absence of mitigation measures, the efficacy of mitigation measures implemented with a given delay, and the expected delay before notification can be provided under the final amendments. In general, data needed to arrive at such estimates are not available to the Commission. Thus, while we have attempted to quantify economic effects where possible, much of the discussion of economic effects is qualitative in nature.

B. Broad Economic Considerations

In a market with complete information, customers are able to perfectly observe the quality of the goods and services being provided and the processes and service provider relationships by which they are being provided. Fully-informed customers can then decide what level of quality of good or service to consume, based on their own personal preferences. In this context, one element of a financial service's quality is the customer information safeguards of the firm providing the service, which capture the likelihood of a customer's information being exposed in the event of a breach, as well as the firm's response to such a breach if it were to

[442] We acknowledge, however, that the final amendments could have incremental effects on capital formation, and we discuss these effects below. *See infra* section IV.E.